Key & Certificate Management Lifecycle — Reference Architecture

Prepared by: Alister A. Rodrigues, Security Analyst, Obsidian SecureTech Solutions

Context: *Enterprise PKI & TLS Certificate Management Framework*

Date: October 2024

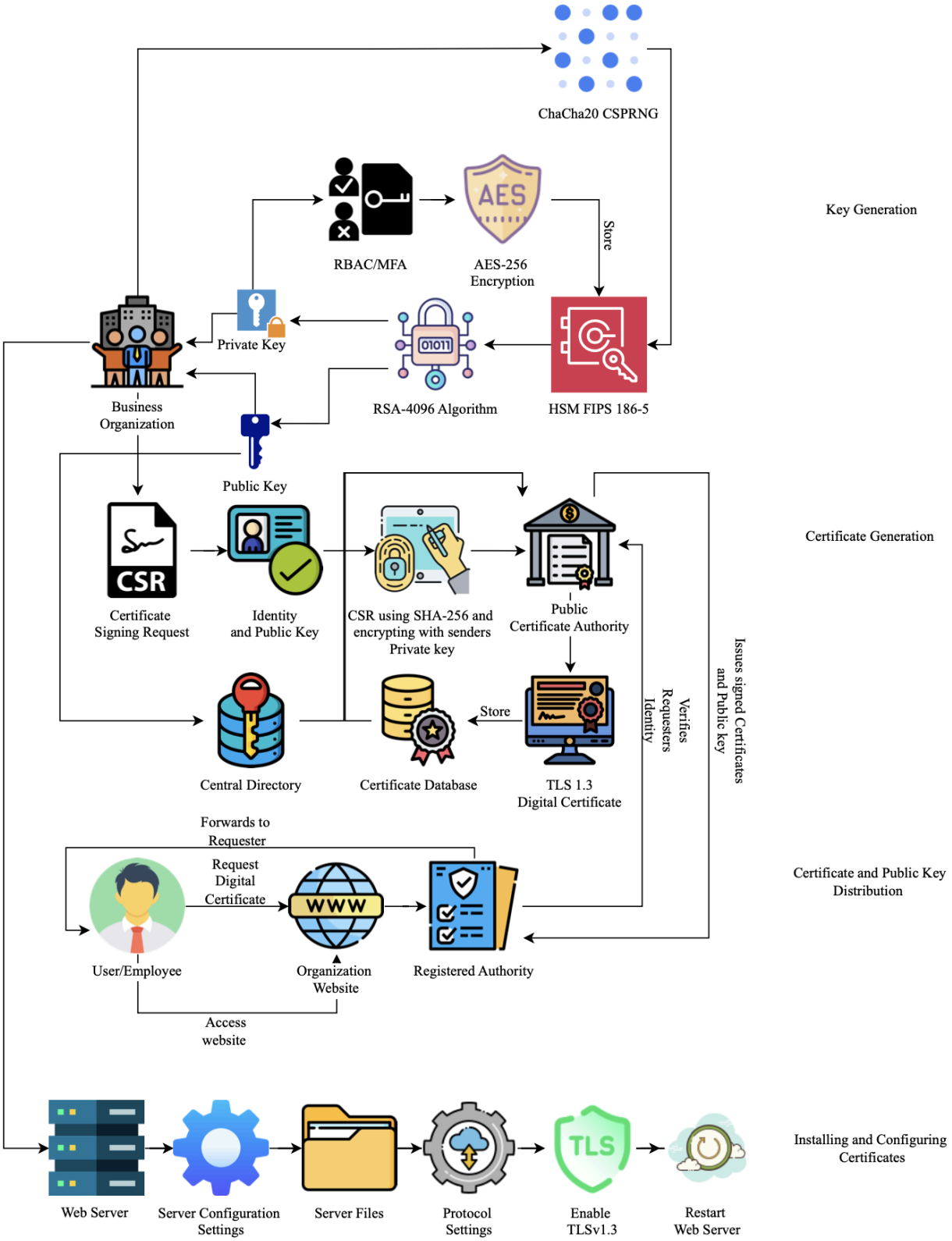
Executive Summary

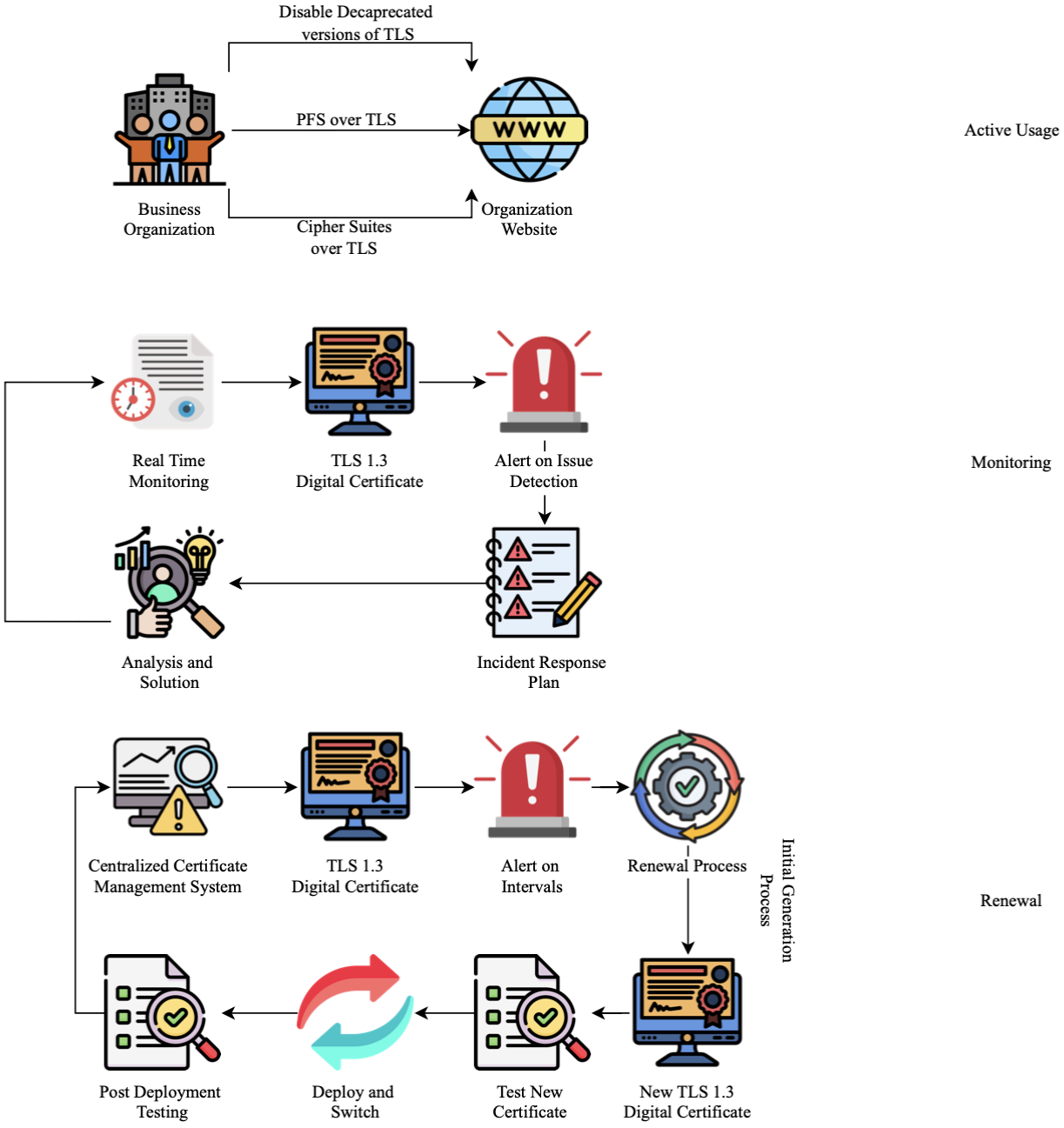
This paper discusses and informs about the approach that the business shall take for its key and certificate Management. The methods and strategies being discussed have been studied and deemed industry best practices toward the business goals.

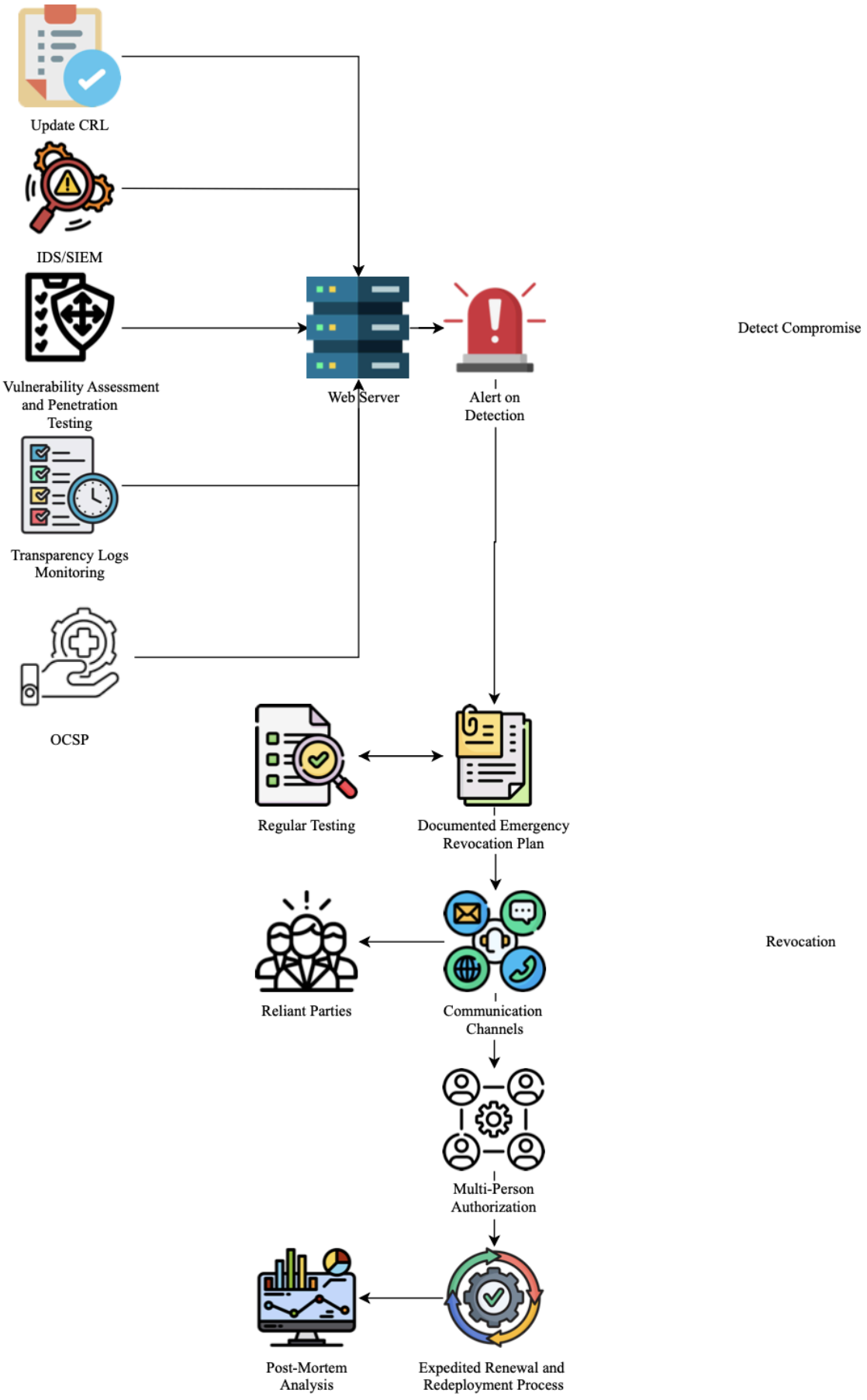
The discussion will begin with the initial stages of key generation and distribution moving toward issuing a digital certificate through an enterprise Certificate Authority and its secure distribution and usage, a reference architecture is provided with visuals detailing the stages of key and certificate management lifecycle including monitoring active usage to renewal, audit and compliance to revocation and decommissioning.

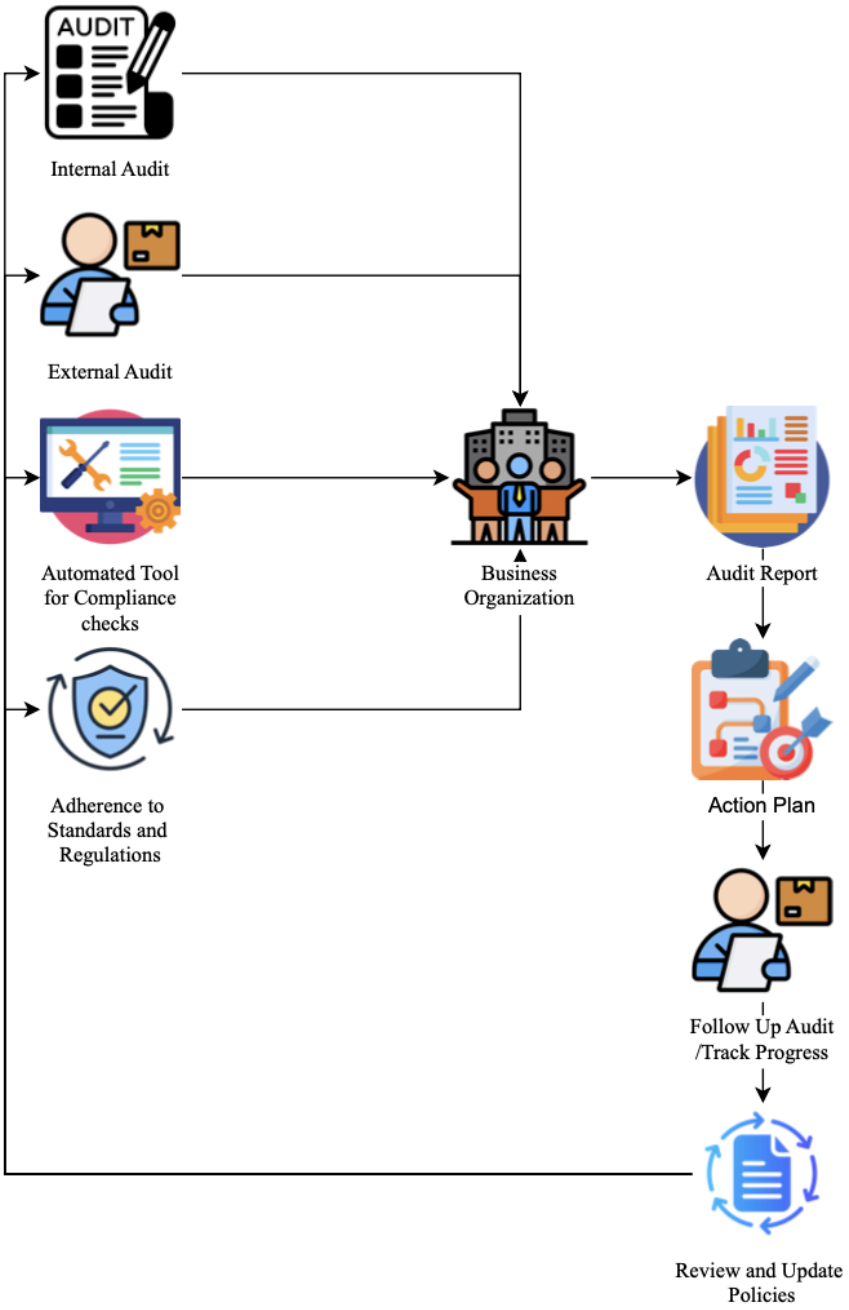
The architecture addresses key generation through secure hardware modules, certificate lifecycle management via an enterprise CA, and end-of-life procedures including secure key destruction and certificate archival.

Reference Architecture

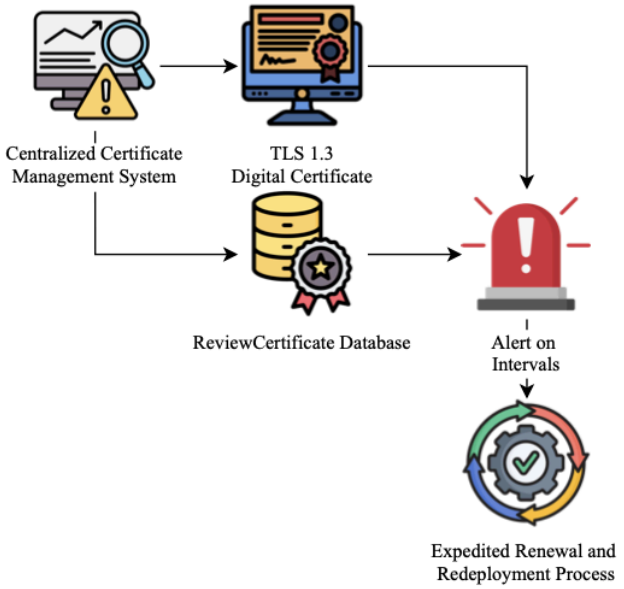



Disable Decaprecated versions of TLS
PFS over TLS
WWW
Business Organization
Cipher Suites over TLS
Organization Website
Active Usage
Real Time Monitoring
TLS 1.3 Digital Certificate
Alert on Issue Detection
Monitoring
Analysis and Solution
Incident Response Plan
Centralized Certificate Management System
TLS 1.3 Digital Certificate
Alert on Intervals
Renewal Process
Initial Generation Process
Renewal
Post Deployment Testing
Deploy and Switch
Test New Certificate
New TLS 1.3 Digital Certificate

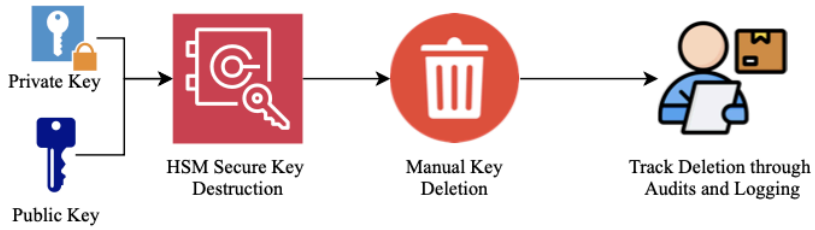

Update CRL
IDS/SIEM
Vulnerability Assessment and Penetration Testing
Transparency Logs Monitoring
OCSP
Web Server
Alert on Detection
Detect Compromise
Regular Testing
Documented Emergency Revocation Plan
Reliant Parties
Communication Channels
Revocation
Multi-Person Authorization
Post-Mortem Analysis
Expedited Renewal and Redeployment Process



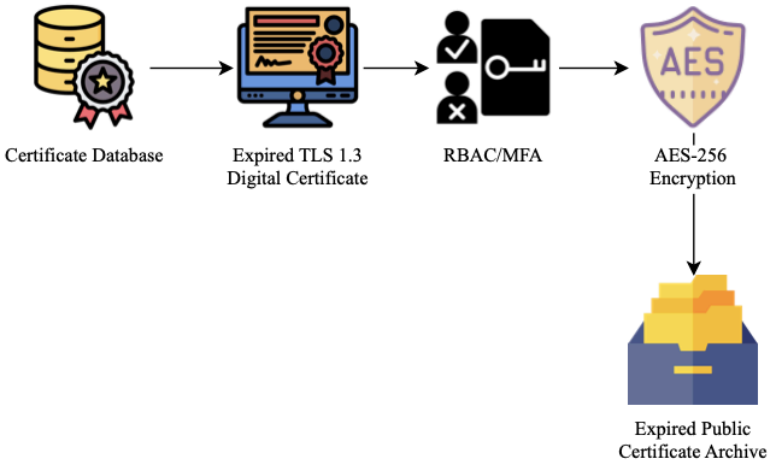
Audit and Compliance



Identification and Renewal of Expired Certificates



Secure Key Deletion



Expired Certificate Archival

Framework and Strategies in Reference Architecture

Key Generation

CHACHA20 a stream cipher software also used as a Cryptographically Secure Pseudo-Random Number Generator (CSPRNG) is fed with high entropy seeds obtained from a mixture of sources i.e operating system entropy and hardware random number generators to ensure unique and true randomness for every output.

This CSPRNG output is fed to the Hardware Security Module (HSM) which is based on FIPS 186-5 standard (Raimondo & Locascio, 2023) and makes use of RSA-4096 encryption algorithm to generate public and private keys.

The private key is then secured with Role Based Access Controls and Multi Factor Authentication and encrypting it with AES-256 before storing it in the HSM. The public key is stored in the central directory.

Certificate Generation

The organization then sends out a Certificate Signing Request (CSR) with all the necessary identification information such as domain name, organization name, country and region along with the public key of the organization. This CSR is signed with the organization's private key to ensure the integrity of the CSR data before being submitted to the enterprise Certificate Authority (CA).

The CA then verifies the identity of the organization and the integrity of the CSR data and issues a Digital Certificate (DC) that the business organization can configure on the website. This Digital Certificate (TLSv1.3) is stored in the Certificate database.

Installing and Configuring Certificates

The Digital Certificate is then configured on to the organizations business website by

accessing the webserver, server config settings, uploading the DC into the server files and then enabling TLSv1.3 from the protocol settings. Restart the webserver for the settings to take effect on the website.

Certificate and Public Key Distribution

When a User or Employee tries to access the website, their data will be first transmitted to a Registered Authority (RA) which will verify the identity of the requester and upon completion will send a request to the Certificate Authority for a Digital Certificate.

The Certificate Authority will then issue a Digital Certificate to the Registered Authority after retrieving an active certificate from the Certificate Database and the public key from the Central Directory.

The Registered Authority forwards this Digital Certificate along with the public key to the requester, upon receiving the certificate and the public key the User/Employee can access the organizations website.

Active Usage

Obsolete and deprecated versions of TLS shall be disabled on the website through protocol settings and Perfect Forward Secrecy (PFS) along with Cipher Suites shall be enabled over TLSv1.3 certificates for enhanced protection (These settings are available by default and just need to be enabled, no extra configuration required).

Monitoring and Renewal

Real time monitoring by the IT team will be done along with the use of the automated Centralized Certificate Management System (CMS). The IT team will be alerted on detection of issues and pre-developed incident response plans will be utilized which will contain majorly known issues and their solutions. For unknown issues, it shall be analyzed and a solution shall be

developed by the IT team and it shall be included in the incident response plan.

The automated Centralized Certificate Management System shall majorly look over the expiration of the certificates and would provide alerts on intervals (eg. 90 days, 60 days, 30 days), upon nearing the expiration it shall automate the renewal process of generating new certificates using new CSR and new keys. The new certificate shall be tested and deployed onto the website using in-built features of the CMS switching out the older certificates in the database, a post deployment test shall be conducted by the IT team to ensure availability and efficiency of the website.

Compromise Detection and Revocation

Security Information and Event Management tools along with Intrusion Detection Systems shall be deployed on the webserver to prevent unauthorized access to the website and detect anomalies by monitoring the Transparency Logs using these tools. Online Certificate Status Protocol (OCSP) stapling shall be enabled for the website along with the updated Certificate Revocation List (CRL) provided by the enterprise Certificate Authority to ensure safe access and prevent misuse of obsolete and defective certificates by anyone accessing the website.

Regular vulnerability assessment and penetration testing shall be conducted on the webserver by the IT team. Upon critical issue detection the pre-documented emergency revocation plan shall be used for revocation of certificates, the plan shall be tested and maintained regularly.

Secure out of bound communication channels shall be used to notify the relying parties and the Multi Person Authorization team (MPA) to prevent any leaks and eavesdropping during communication. After authorization by the MPA protocol Expedited renewal and redeployment of certificates is done using the automated Centralized Certificate Management System. A

post-mortem analysis shall be conducted and documented to prevent future failures.

Audit and Compliance

Internal and External audits using third party services shall be conducted quarterly along with automated tools to ensure compliance and adherence to the standards and regulations for key and certificate lifecycle management eg. PCI DSS (*Payment Card Industry Data Security Standard Requirements and Testing Procedures Version 4.0.1*, 2024), GDPR (*Key and Certificate Management | Search | Information Commissioner's Office*, 2020), ISO (*ISO 27001:2022 Annex a 8.24 – Use of Cryptography*, 2022), NIST 800-57 (Barker, 2020), NIST.SP.1800-16 (Akram et al., 2020).

An audit report will be created combined with the internal and external audit processes conducted, a suitable action plan shall developed for the issues detected, during the process of developing the action plan and implementing it, a follow up audit will be conducted to track the resolution process after final implementation organizations policies shall be reviewed and updated for compliance with the latest standards and regulations.

End of life Process for Key and Certificate Management

Certificate databases will be scanned to check for expired certificates, if found the certificates will then be encrypted using AES-256 and controlled using Role Based Access Controls along with Multi Factor Authentication before being archived and stored in a separate database.

The private key shall be securely destroyed using HSM built-in secure key destruction, supplemented by manual verification to confirm complete disposal and prevent misuse, the destruction process shall be overseen by auditing and logging. The public key shall be encrypted and controlled with access controls just like expired certificates before being stored into a private directory.

Figure 1 : Flowchart for Key and Certificate generation

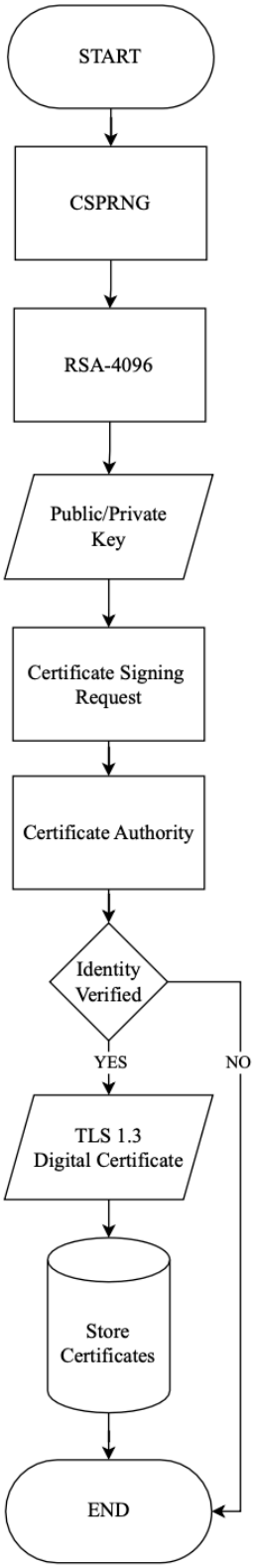


Figure 2 : Flowchart for Key and Certificate distribution

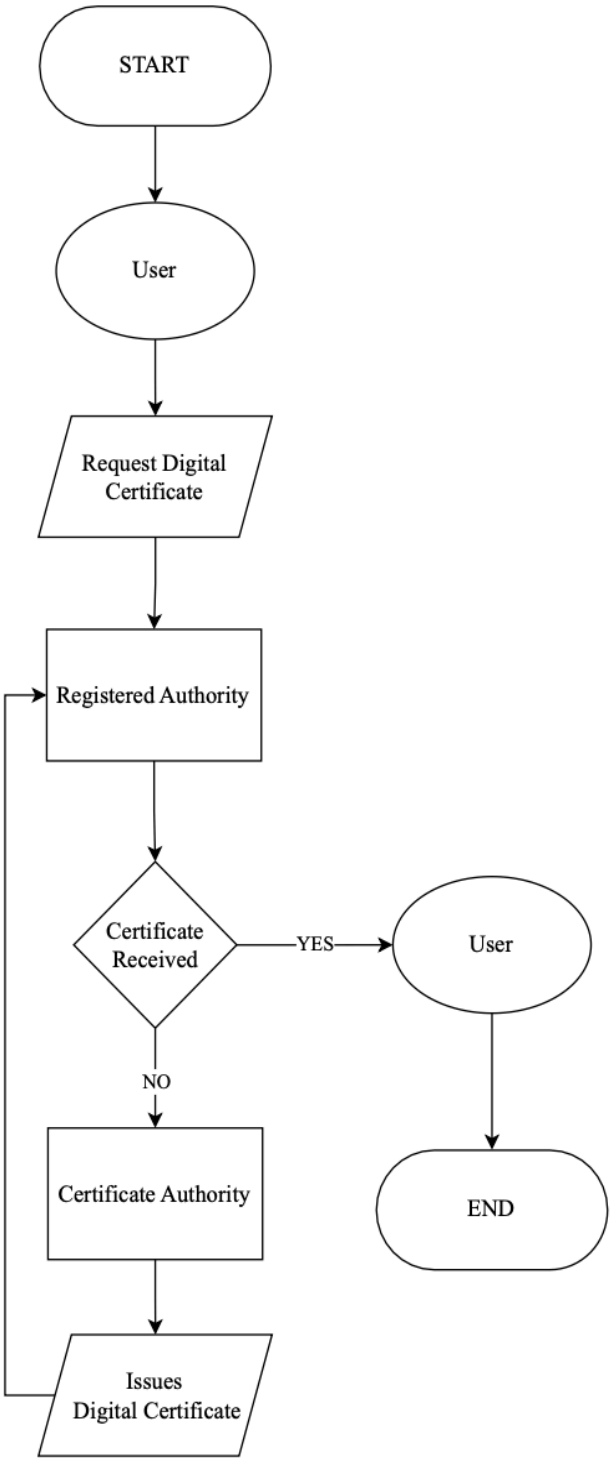


Figure 3 : Flowchart for Monitoring and Renewal

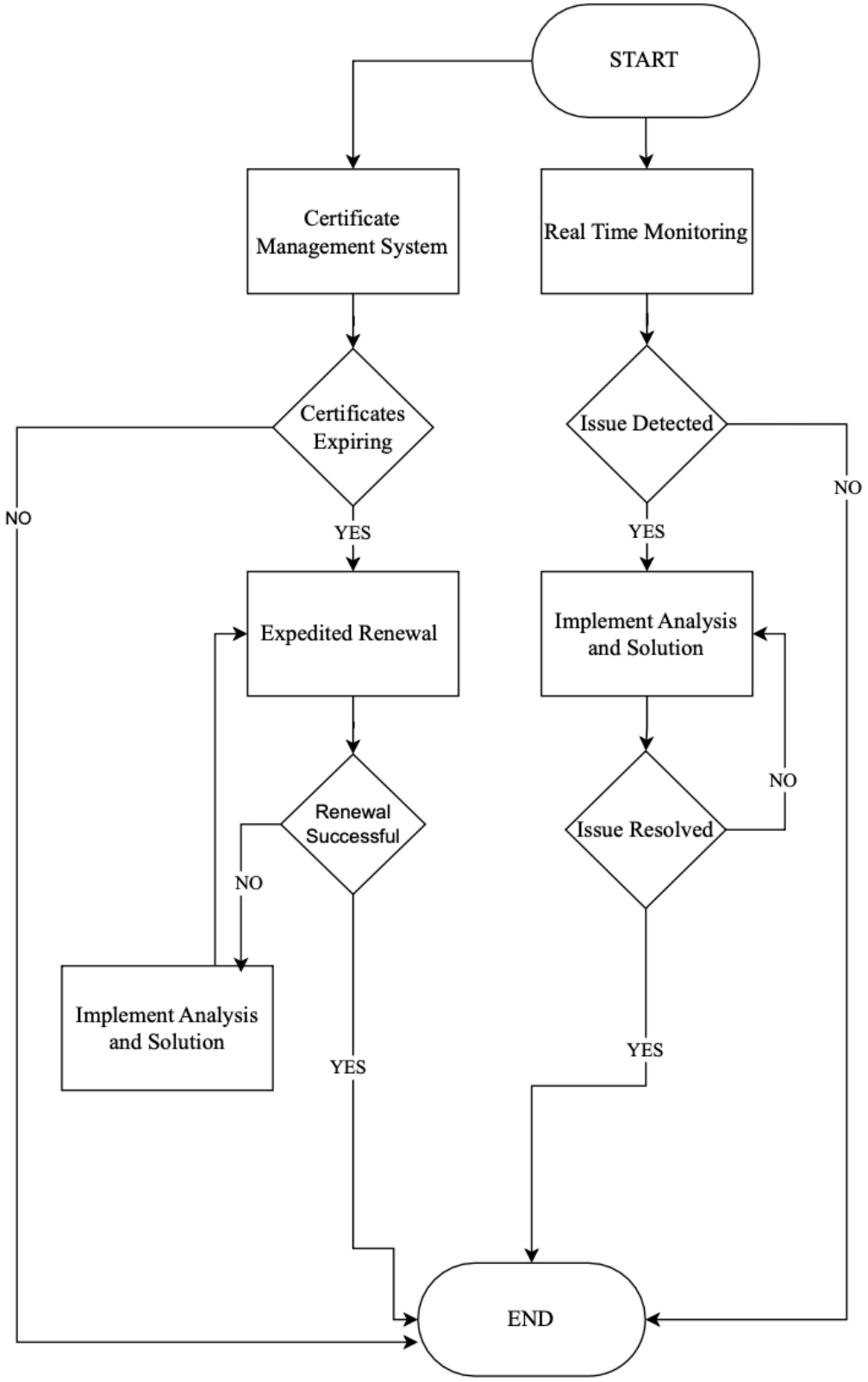
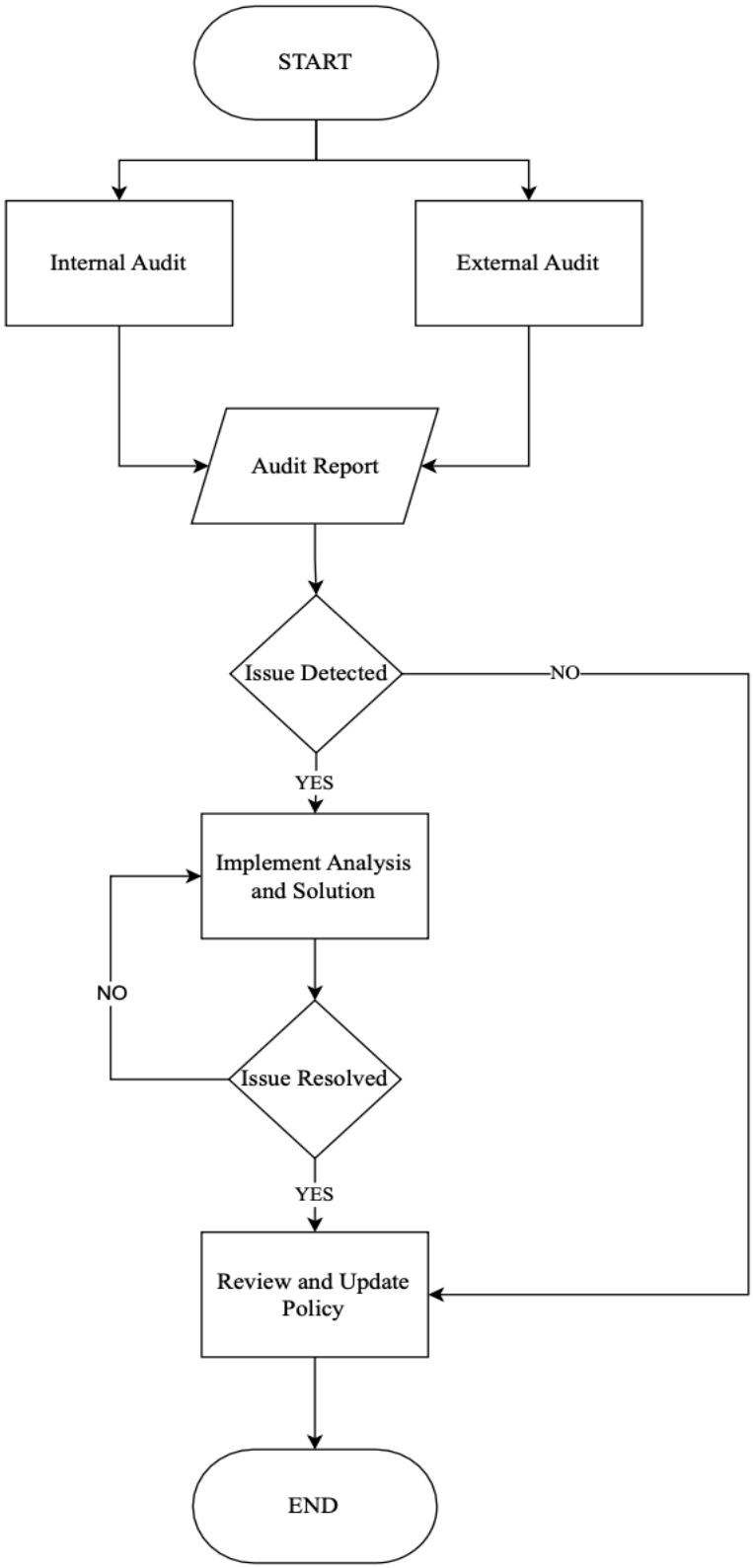


Figure 4 : Flowchart for Audit and Compliance



References

Akram, M., et al. (2020). *Securing Web Transactions: TLS Server Certificate Management*, *1800-16*. https://doi.org/10.6028/NIST.SP.1800-16

Barker, E. (2020). Recommendation for key management: *NIST Special Publication 800-57 Part 1 Revision 5*. https://doi.org/10.6028/nist.sp.800-57pt1r5

ISO 27001:2022 Annex A 8.24 – Use of Cryptography. (2022). ISMS.online. https://www.isms.online/iso-27001/annex-a/8-24-use-of-cryptography-2022/

key and certificate management | Search | Information Commissioner's Office. (2020). Ico.org.uk. https://icosearch.ico.org.uk/s/search.html?query=key+and+certificate+management&collection=ico-meta&profile=_default&f.Website+Section%7Csection=For+organisations

Payment Card Industry Data Security Standard Requirements and Testing Procedures Version 4.0.1. (2024). https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4_0_1.pdf

Raimondo, G., & Locascio, L. (2023). FIPS 186-5 FEDERAL INFORMATION PROCESSING STANDARDS PUBLICATION Digital Signature Standard (DSS) CATEGORY: COMPUTER SECURITY SUBCATEGORY: CRYPTOGRAPHY. *Digital Signature Standard (DSS)*, *Federal Information Processing Standard (FIPS) 186-5*(FIPS 186-5). https://doi.org/10.6028/NIST.FIPS.186-5